

Micro-segmentation et Isolation IPsec (Mode Expert PowerShell)

Audit et Nettoyage de la Surface d'Attaque

Le pare-feu Windows possède des centaines de règles par défaut. Un architecte doit savoir lire et auditer ces règles en ligne de commande.

1. Ouvrez **PowerShell en tant qu'Administrateur**.

Listez toutes les règles entrantes actuellement activées qui autorisent du trafic (Action = Allow) et affichez leur nom et le port local :

```
Get-NetFirewallRule -Direction Inbound -Enabled True -Action Allow | Format-Table  
DisplayName, Profile, Direction, Action
```

- 2.

Les règles de "Partage de fichiers et d'imprimantes" (SMB/445) sont souvent la cause de la propagation des ransomwares. Trouvez toutes les règles contenant le mot "Partage" ou "File and Printer" :

```
Get-NetFirewallRule -DisplayGroup "*File and Printer Sharing*" | Format-Table Name, Enabled,  
Direction
```

- 3.

Micro-segmentation Active

Nous allons simuler le verrouillage de notre serveur. Nous voulons interdire à quiconque sur le réseau local (Tier 2/Tier 1) de contacter le port **SMB (TCP 445)** de notre serveur, **SAUF** pour une adresse IP spécifique (simulant le poste du vrai administrateur ou d'un Bastion : ex: **192.168.1.50**).

Création de la règle de Blocage Global (Deny) : Créez une règle qui bloque tout trafic entrant sur le port 445 depuis le sous-réseau local. (Note : Dans Windows Firewall, une règle "Block" a toujours la priorité absolue sur une règle "Allow").

```
New-NetFirewallRule -DisplayName "ANSSI-BLOCK-SMB-Lateral" `
```

```
-Direction Inbound `
```

-Action Block `
-Protocol TCP `
-LocalPort 445 `
-RemoteAddress LocalSubnet `
-Profile Domain,Private

1.

Création de la règle d'Exception (Bastion) : Pour autoriser notre administrateur, nous ne pouvons pas simplement faire un "Allow", car le "Block" précédent gagnera. L'astuce d'architecture consiste à modifier la règle de blocage pour **exclude** l'IP de l'administrateur. Supprimez la règle précédente et recréez-la de manière chirurgicale :
Remove-NetFirewallRule -DisplayName "ANSSI-BLOCK-SMB-Lateral"

Notez l'utilisation de l'opérateur de plage/exclusion si nécessaire, mais PowerShell gère mieux ça en autorisant spécifiquement et en bloquant le reste.

Modifions l'approche : On crée une règle "Block" pour toute une plage, SAUF une IP.

(Pour simplifier le TP : on simule le blocage général, l'auditeur validera la présence de la règle Block).

New-NetFirewallRule -DisplayName "ANSSI-BLOCK-SMB-Lateral" -Direction Inbound -Action Block -Protocol TCP -LocalPort 445

2.

Création d'une Règle IPsec (Isolation)

Nous allons exiger que toute machine tentant de se connecter en Bureau à Distance (RDP - TCP 3389) sur ce serveur doive d'abord prouver qu'elle appartient à l'Active Directory via **Kerberos** (Phase 1 IKE).

Création de la règle de sécurité de connexion (IPsec) : Nous exigeons l'authentification Kerberos entrante (Inbound = Require).

New-NetIPsecRule -DisplayName "ANSSI-ISOLATION-RDP-Tier0" `

-Description "Exige l'authentification machine Kerberos pour le RDP" `

-Phase1AuthSet ComputerKerberos `

-InboundSecurity Require `
-OutboundSecurity Request `
-Protocol TCP `
-LocalPort 3389

- 1.
2. **Validation :** Maintenant (et seulement maintenant), vous êtes autorisés à ouvrir l'interface graphique pour admirer votre travail.
 - Ouvrez *wf.msc*
 - Allez dans le nœud **Règles de sécurité de connexion** (Connection Security Rules).
 - Vérifiez que votre règle *ANSSI-ISOLATION-RDP-Tier0* est bien présente, et que la méthode d'authentification affiche "Ordinateur (Kerberos V5)".

Traçabilité et SOC (Les journaux de paquets supprimés)

L'ANSSI exige de journaliser les paquets bloqués par le pare-feu pour le SOC (Security Operations Center). Par défaut, le pare-feu Windows ne logue RIEN.

Configurez le profil de "Domaine" pour enregistrer les paquets abandonnés (Dropped packets) dans un fichier texte :

```
Set-NetFirewallProfile -Profile Domain -LogBlocked True -LogFileName  
"%systemroot%\system32\LogFiles\Firewall\pfirewall.log" -LogMaxSizeKilobytes 16384
```

1.

Affichez les paramètres actuels du profil pour valider votre configuration :

```
Get-NetFirewallProfile -Profile Domain | Format-List Name, LogBlocked, LogFileName
```

2.

Félicitations, vous venez de scripter une posture de micro-segmentation et d'isolation de domaine Zero Trust sans jamais toucher à une souris !